

Capstone Assessment: Prioritized Risk Analysis for ConnectSphere

Submitted by: Hope Hirwa Rukundo
Role assumed: Independent Cybersecurity Governance Consultant
Task: Set 1 ConnectSphere Professional Event Networking MVP
Module: Cybersecurity Fundamentals for Modern Tech Roles
Date: 11 August 2026

Content

- 1. Engagement Context..... 1
- 2. Objectives..... 2
- 3. Methodology..... 2
- Deliverable 1 — Cybersecurity Governance Review Card..... 2
- Deliverable 2: Corrected Architecture Diagram..... 4
 - Explained corrections..... 6
- Deliverable 3 — Summary of Review Process..... 7
- Course Resources Referenced..... 7

1. Engagement Context

ConnectSphere is a fast-growing professional-networking startup whose founders have a Series A term sheet on the table contingent on passing a security due-diligence review within fourteen days. With no in-house security hire yet, the CTO engaged me, as an independent cybersecurity governance consultant, to review the platform's design and processes before the investors' own auditors do.

This report covers Set 1 of the ConnectSphere brief: the Professional Event Networking MVP, whose core functionality is user profiles, event registration, and in-app messaging, and which handles PII (name, email, phone, company, title) plus event registration data. The internal audit that triggered this engagement flagged five preliminary concerns: unencrypted transmission of sensitive data, overly permissive API endpoints, missing

input validation, poorly defined access-control roles, and the absence of incident-response or logging mechanisms. Each of those concerns is traceable to a specific, marked flaw in the Set 1 architecture diagram reviewed below.

2. Objectives

- **Identify Security Risks** detect and classify risks related to data protection, access control, and system design.
- **Apply Cybersecurity Principles:** reference the CIA Triad, Principle of Least Privilege (PoLP), and Secure SDLC practices.
- **Ensure Compliance:** Assess alignment with GDPR and CCPA.
- **Recommend Actionable Fixes:** propose practical, governance-aligned mitigations.

3. Methodology

I reviewed the Set 1 project brief and its architecture diagram side by side, tracing each data flow (**client → load balancer → web servers → API Gateway/backend → database, plus the phone-verification and SMS-gateway paths**) and checking it against the CIA Triad, PoLP, and Secure SDLC / "Shift Left" thinking covered in the course. Findings were prioritized by how many CIA properties each flaw compromised and cross-referenced against the course's own readings ISACA on why security is everyone's job, the OWASP Top 10 for injection risk, Microsoft Learn's IAM material for authentication/authorization and PoLP, the Splunk guide to encryption, and the SecurityMetrics Incident Response phases so every finding below is grounded in a specific course resource, not just general knowledge.

Deliverable 1 — Cybersecurity Governance Review Card

Three distinct risk findings, each mapped to a core governance principle, plus one monitoring recommendation.

Section	Issue / Definition	Impact	Suggested Fix / Mitigation
1. Confidentiality Risk	PII (name, email, phone, company, title) and session data travel over unencrypted HTTP between client and both web servers, and again between the web tier and the database, a direct violation of the Confidentiality leg of the CIA Triad.	Anyone positioned on the network path (public Wi-Fi, ISP, or a compromised internal segment) can intercept credentials and PII in plaintext, enabling identity theft and credential replay ahead of the Series A due-diligence review.	Terminate TLS 1.2+/HTTPS at the Load Balancer, enforce it end-to-end to both web servers and from the app tier to the database, redirect all HTTP to HTTPS, and disable legacy ciphers.
2. Integrity Risk	The Application Backend builds SQL queries without prepared statements, so user input reaches the database as raw, unsanitized SQL, a classic SQL Injection flaw and a breach of secure input-validation practice.	An attacker can inject SQL to alter, delete, or exfiltrate records, e.g., editing another user's profile, forging registrations, or dumping the PII table, undermining the accuracy and trustworthiness of stored data.	Refactor all database calls to parameterized queries / prepared statements (or a vetted ORM), add server-side input validation and allow-listing, and add a WAF (e.g. OWASP Core Rule Set) as a compensating control.
3. Availability Risk	The Admin Dashboard is reachable with "Public, No Auth" directly against the User Database, a Principle-of-Least-Privilege failure that leaves no barrier against volumetric abuse or destructive mass requests.	Without authentication or rate limiting, the endpoint can be used accidentally or maliciously to overload or corrupt the database at scale, degrading or taking down the service for legitimate users.	Require authenticated, role-based access (PoLP) for the Admin Dashboard behind the API Gateway with rate limiting and IP allow-listing; add connection throttling / read replicas so no single client can exhaust the primary DB.

Section	Issue / Definition	Impact	Suggested Fix / Mitigation
4. Monitoring / Reporting Recommendation	Metric: "Unauthorized / Failed Access Attempts per Endpoint" failed logins, 401/403 responses, and requests to the Admin Dashboard or API Gateway from unrecognized sessions, tracked hourly.	Visualization: Heatmap (endpoint x hour) to spot spikes, paired with a Line chart to show trends over time.	Rising unauthorized-access attempts are the earliest signal of credential-stuffing or privilege-escalation activity, supporting the "Identification" phase of Incident Response and giving auditors evidence of active governance.

Grounded in course materials:

Confidentiality Risk: Splunk, "Data Encryption Methods & Types: A Beginner's Guide" (**Topic 3**).

Integrity Risk: OWASP, "OWASP Top 10 2021 Introduction" (**Topic 2: Injection**).

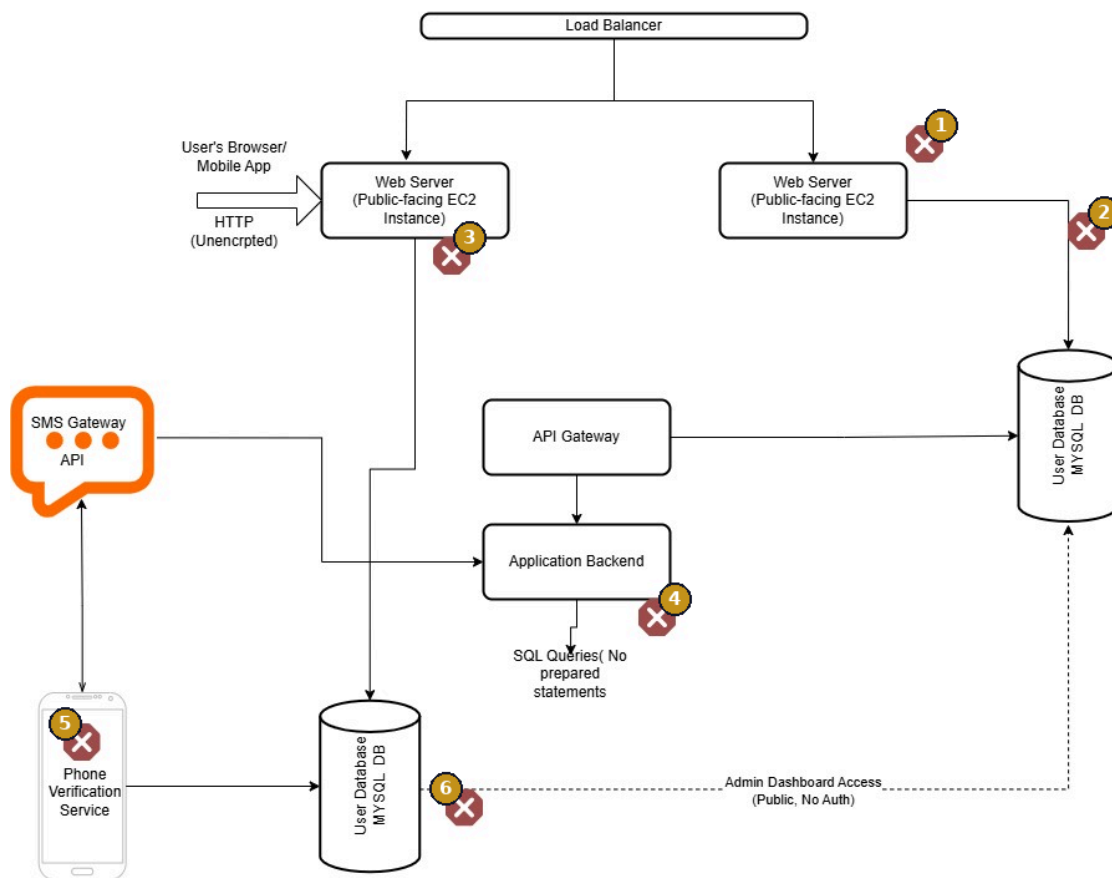
Availability Risk: Microsoft Learn, "Identity and Access Management (IAM): Core Concepts" (**Topic 3: Principle of Least Privilege**).

Monitoring Recommendation: SecurityMetrics, "The 6 Phases of an Incident Response Plan" (**Topic 5: Identification phase**).

Deliverable 2: Corrected Architecture Diagram

The diagram below reproduces the original Set 1 flow with each pre-marked flaw numbered and cross-referenced to the correction it requires.

ConnectSphere User Flow (Set 1)



ANNOTATED CORRECTIONS — SET 1

- 1 Enforce HTTPS/TLS end-to-end on the Load Balancer and BOTH web server instances.**
 Only the left path is currently flagged unencrypted; the second server needs identical TLS termination so no request path silently falls back to HTTP. Protects Confidentiality of data-in-transit.
- 2 Encrypt the web-server-to-database connection (TLS for DB traffic, not just the client-facing hop).**
 An attacker on the internal network could otherwise sniff PII in plaintext between the app tier and data tier. Confidentiality (CIA Triad).
- 3 Encrypt and authenticate the internal link from the web server down to the database/backend.**
 Internal traffic is not inherently trustworthy — apply the same in-transit encryption standard internally as externally. Confidentiality.
- 4 Replace raw SQL string concatenation with parameterized queries / prepared statements, plus input validation.**
 Removes the SQL Injection vector, which could let an attacker read, modify, or delete records — protects data Integrity (OWASP Top 10 #1 risk).
- 5 Route phone/OTP verification through an authenticated, encrypted channel with rate limiting.**
 An unsecured verification path can be bypassed or intercepted, undermining identity assurance for every account created downstream.
- 6 Remove public access to the Admin Dashboard; require authenticated, role-based access (PoLP) only, and log all admin actions.**
 Most severe finding: an unauthenticated path straight into the user database. Fixing it protects Confidentiality/Integrity and enables audit logging for Incident Response.

Explained corrections

1. Enforce HTTPS/TLS end-to-end on the Load Balancer and BOTH web server instances.

Only the left path was flagged unencrypted in the original diagram; the second server needs identical TLS termination so no request path silently falls back to HTTP. Protects Confidentiality.

Course reference: Splunk, "Data Encryption Methods & Types: A Beginner's Guide" (Topic 3 — encryption in-transit vs. at-rest).

2. Encrypt the web-server-to-database connection (TLS for DB traffic, not just the client-facing hop).

An attacker on the internal network could otherwise sniff PII in plaintext between the app tier and data tier. Confidentiality (CIA Triad).

Course reference: Splunk, "Data Encryption Methods & Types" (Topic 3).

3. Encrypt and authenticate the internal link from the web server down to the database/backend.

Internal traffic is not inherently trustworthy; apply the same in-transit encryption standard internally as externally. Confidentiality.

Course reference: Microsoft Learn, "Identity and Access Management (IAM): Core Concepts" (Topic 3 — authentication of internal service calls).

4. Replace raw SQL string concatenation with parameterized queries / prepared statements, plus input validation.

Removes the SQL Injection vector, which could let an attacker read, modify, or delete records. Integrity (OWASP Top 10 #1 risk).

Course reference: OWASP, "OWASP Top 10 2021 Introduction" (Topic 2 — Injection).

5. Route phone/OTP verification through an authenticated, encrypted channel with rate limiting.

An unsecured verification path can be bypassed or intercepted, undermining identity assurance for every account created downstream. Confidentiality / secure session management.

Course reference: Microsoft Learn, "Identity and Access Management (IAM): Core Concepts" (Topic 3 — Authentication vs. Authorization, MFA).

6. Remove public access to the Admin Dashboard; require authenticated, role-based access (PoLP) only, and log all admin actions.

The most severe finding: an unauthenticated path straight into the user database. Fixing it protects Confidentiality and Integrity, and enables audit logging for Incident Response.

Course reference: Microsoft Learn, "IAM: Core Concepts" (PoLP) and SecurityMetrics, "The 6 Phases of an Incident Response Plan" (Topic 5 — audit logging).

Deliverable 3 — Summary of Review Process

This review used the CIA Triad, introduced in Topic 1 through the ISACA reading and the course's overview video, as the primary lens for evaluating the Set 1 architecture: every data flow was checked for Confidentiality (is it encrypted and restricted to authorized parties?), Integrity (can the data be trusted, or is it exposed to injection?), and Availability (can the system be knocked down by an unauthenticated or unthrottled path?). The Principle of Least Privilege, from Microsoft Learn's IAM material in Topic 3, was used specifically to evaluate the Admin Dashboard, which had no authentication gating direct access to the User Database, the single highest-priority finding, since it collapses all three CIA properties into one exposed endpoint. Secure SDLC / "Shift Left" thinking framed the SQL Injection finding, sourced from the OWASP Top 10 reading in Topic 2: the absence of prepared statements shows input validation was never built in early, so the fix is a coding-practice change, not just a network control.

Together, the three findings and their mitigations move ConnectSphere closer to GDPR- and CCPA-aligned data protection, both introduced in Topic 5: encrypting PII in transit (per the Splunk encryption reading) satisfies baseline confidentiality obligations, parameterized queries protect the accuracy of the personal data those laws require organizations to safeguard, and closing the open Admin Dashboard demonstrates the access accountability regulators and auditors expect to see documented.

The recommended monitoring metric unauthorized and failed access attempts per endpoint was chosen because it supports transparent, ethical governance: drawing on the SecurityMetrics Incident Response reading from Topic 5, it gives ConnectSphere an evidence trail for the Identification phase, turns security into an ongoing observable practice rather than a one-time audit, and gives the CTO something concrete to show investors' auditors as proof that risks are being actively watched.

Course Resources Referenced

- **ISACA:** "The Reason Why Cybersecurity Is Still Everyone's Job" (**Topic 1**).

- **OWASP:** "OWASP Top 10 2021 Introduction" (**Topic 2**).
- **Microsoft Learn:** "Identity and Access Management (IAM): Core Concepts" (**Topic 3**).
- **Splunk:** "Data Encryption Methods & Types: A Beginner's Guide" (**Topic 3**).
- [GDPR.eu](#): "What is GDPR? The EU's General Data Protection Regulation" (**Topic 5**).
- **SecurityMetrics:** "The 6 Phases of an Incident Response Plan" (**Topic 5**).